

CHAPTER TWO

LITERATURE REVIEW

2.1 Theoretical Review

Access control as a formal subject predates RBAC by decades, and it's worth starting there rather than jumping straight to the model this project uses. Saltzer and Schroeder's 1975 paper, *The Protection of Information in Computer Systems*, is still the reference point most later work builds on. It set out a small number of design principles for protection mechanisms: least privilege, complete mediation, fail-safe defaults, economy of mechanism, separation of privilege, and a few others less directly relevant here. Least privilege in particular, the idea that a user or process should hold no more access than the task in front of it requires, is close to the founding intuition behind RBAC, even though Saltzer and Schroeder weren't describing role-based systems specifically. The decorator-based permission checks in this project's `accounts` app, each denying access unless a request comes from a user holding the specific role a view requires, are a fairly direct application of that principle at the code level.

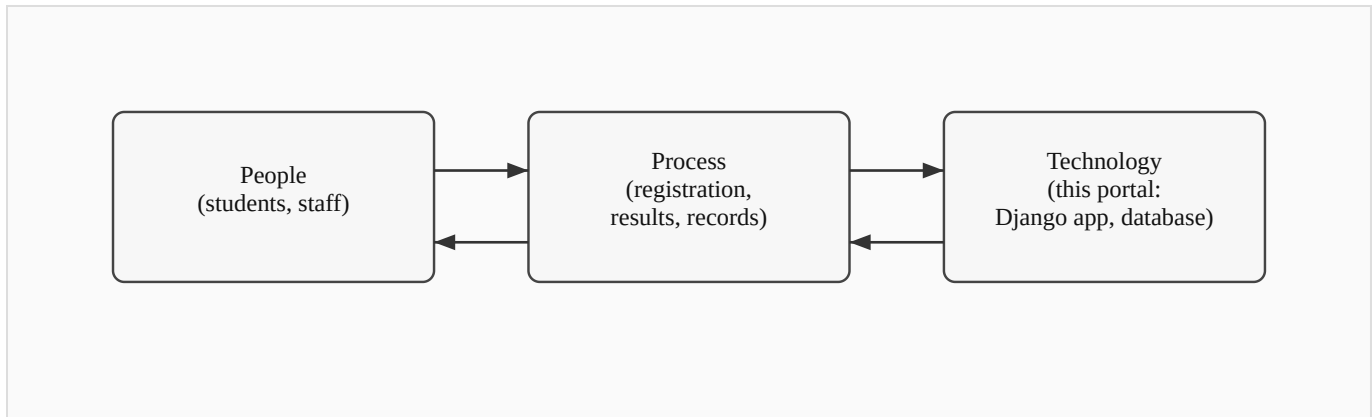
Role-Based Access Control itself was formalized by Ferraiolo and Kuhn in their 1992 paper for the National Computer Security Conference. Their argument was that neither of the two dominant models at the time, discretionary access control (where the resource owner decides who gets access) and mandatory access control (where a central authority assigns fixed security labels), matched how organizations actually managed access in practice. Most organizations think in terms of job functions: a registrar does registrar things, a lecturer does lecturer things, and access should follow that structure rather than being assigned person by person or locked to a rigid label. RBAC introduces the role as an intermediate layer between users and permissions, so permissions attach to roles and users are assigned to roles, rather than permissions attaching to individual users directly.

Sandhu, Coyne, Feinstein, and Youman took that idea further in 1996, publishing a family of four reference models in IEEE Computer, usually referred to as RBAC96. The simplest, flat RBAC, is close to what this project implements: users hold roles, roles hold permissions, and that's the whole picture. Their more elaborate models add role hierarchies (where a senior role inherits a junior role's permissions) and constraints (such as mutually exclusive roles, where the same user can never hold two conflicting roles at once). This project doesn't need role hierarchies or exclusion constraints. Its seven roles are largely independent of one another, and a Django Group per role, checked by one decorator per view, covers the requirement without the added complexity RBAC96's fuller models bring.

Beyond access control specifically, Laudon and Laudon's *Management Information Systems: Managing the Digital Firm* frames the broader point of a system like this one: an information system isn't just software, it's a combination of people, process, and technology built to solve an organizational problem.

That framing matters for how Chapter Three approaches the existing (manual) system and the proposed one. The technology is the part this report spends the most time on, but the actual problem being solved, slow and error-prone administrative processes at a specific university, is organizational first and technical second.

Figure 2.1: Basic System Components (*sketch below; to be redrawn for final submission*)



Every basic information system, this one included, is this same triangle: people with a job to do, a process that job follows, and technology that supports the process. RBAC sits inside the "technology" corner, but it only matters because of what it does for the other two: it changes how the process runs (an unauthorized edit is refused rather than merely discouraged) and what people can rely on (a student trusts their result once entered, without needing to double-check it against a paper copy somewhere else).

Stallings and Brown's *Computer Security: Principles and Practice* rounds out the theoretical base, covering the practical side of authentication, session management, and the general shape of access-control enforcement in a running system, rather than the RBAC model in isolation. Several of the concrete choices in Chapter Four, session expiry after a period of inactivity, an account lockout after repeated failed logins, CSRF protection on every form, trace back to standard practice as described in that text rather than to any one paper.

2.2 Review of Related Literature

Within a Nigerian tertiary-education setting specifically, RBAC has already been applied, though narrowly. Onashoga, Abayomi-Alli, and Ogunseye (2014), working out of the Federal University of Agriculture, Abeokuta, built a Role-Based Examination System aimed at a fairly specific problem: examination questions and results being exposed to users who had no business seeing them, because the systems handling those documents had no real access control layered on top of basic authentication. Their system combined two authentication techniques with role-based checks to keep exam materials scoped to the people who should see them at each stage of the process, and it's a useful data point that RBAC as a concept has already been tested, successfully, in a Nigerian university context. What it doesn't do is extend that model past examinations into the wider set of administrative functions, course registration, student records, results publication, that a full institutional portal has to cover. That's the gap this project sits in.

Looking at what's already running at other Nigerian universities gives a sense of what a fuller system looks like once resources aren't a constraint. The University of Nigeria, Nsukka runs a student portal (unnportal.unn.edu.ng) covering course registration, fee payment, result checking, admission status, transcript requests, the academic calendar, and admission deferment, among other functions. Covenant University's portal (portal.covenantuniversity.edu.ng) covers much the same ground, plus hostel allocation and online clearance. Both are broad, mature systems built for large student populations at well-established universities, and neither publishes any account of the access-control architecture underneath the features a student or staff member actually sees. That's a reasonable choice for a production system not built to be studied, but it also means there's no public record of how either institution actually structured its role-based permissions, if RBAC is even the model either one uses.

Legacy University sits in a different position from both of the reference institutions above: newly established, smaller, and without the budget or in-house development team a UNN or a Covenant University can draw on. A portal built for it needs to solve the same class of problem, centralizing records, scoping access by role, cutting down on manual paperwork, at a scale and cost that a single developer working within a final year project timeline can actually deliver. None of the case studies reviewed here address that specific combination: a smaller Nigerian institution, a documented RBAC design rather than an opaque production system, and a scope deliberately kept small enough to be buildable and verifiable within an academic project's constraints.

2.3 Summary of Literature Review (in Tabular Form) and Knowledge Gap

Author(s) / Year	Focus	Relevance to this project
Saltzer & Schroeder (1975)	Design principles for protection mechanisms in computer systems	Grounds the least-privilege reasoning behind the per-role decorator design in Chapter Four
Ferraiolo & Kuhn (1992)	Formalizes Role-Based Access Control as an alternative to DAC/MAC	Source of the core model this project's RBAC layer implements
Sandhu, Coyne, Feinstein & Youman (1996)	RBAC96 family of reference models (flat, hierarchical, constrained, symmetric)	Establishes that flat RBAC, the simplest model in the family, is a legitimate and sufficient choice for a system with independent, non-hierarchical roles
Laudon & Laudon (2020)	Information systems as combinations of people, process, and technology	Frames the portal as a response to an organizational problem, not just a technical exercise
Stallings & Brown (2018)	Applied computer security: authentication, session management, access control in practice	Basis for the session-timeout, logout, and CSRF design choices covered in Chapter Four
Onashoga, Abayomi-Alli & Ogunseye (2014)	RBAC applied to a Nigerian university's electronic examination system	Confirms RBAC's feasibility in a Nigerian tertiary context, but scoped narrowly to examinations
UNN and Covenant University portals (case studies)	Large-scale, feature-rich institutional student portals	Show what a fully-resourced portal covers, but neither documents its underlying access-control design

Between them, these sources establish RBAC as a sound, well-studied model and show it already working in at least one Nigerian academic context; the UNN and Covenant University case studies round that out by showing what a large-scale institutional portal looks like once resources aren't a limiting factor. None of it offers an example that sits in the middle, though: a documented, openly-designed RBAC system built at the scale a single developer can realistically deliver, for an institution the size of Legacy University rather than an already-established, well-resourced one. That's the specific gap this project addresses, and Chapter Three picks up from here with an analysis of Legacy University's existing (manual) system against the one proposed to replace it.